



One-Person Army: Automating Enterprise Security with GenAI

Anthony Castano

One person. An enterprise attack surface.

- Security always runs behind
- Headcount that looks like a startup's
- Solo doesn't mean siloed
- GenAI is the multiplier that closes the





SHOW OF HANDS

**Who here is the only security
person at their org?**

Keep your hand up if you are also the help desk.

~whoami

- Cybersecurity analyst. 9 years in IT. Construction.
- Service Desk → Infrastructure → Security
- Enterprise security: cloud & on-prem
- Threat analysis, IR, IAM, vulnerability mgmt
- Team of one
- Not a dev
- Travel & gaming enthusiast



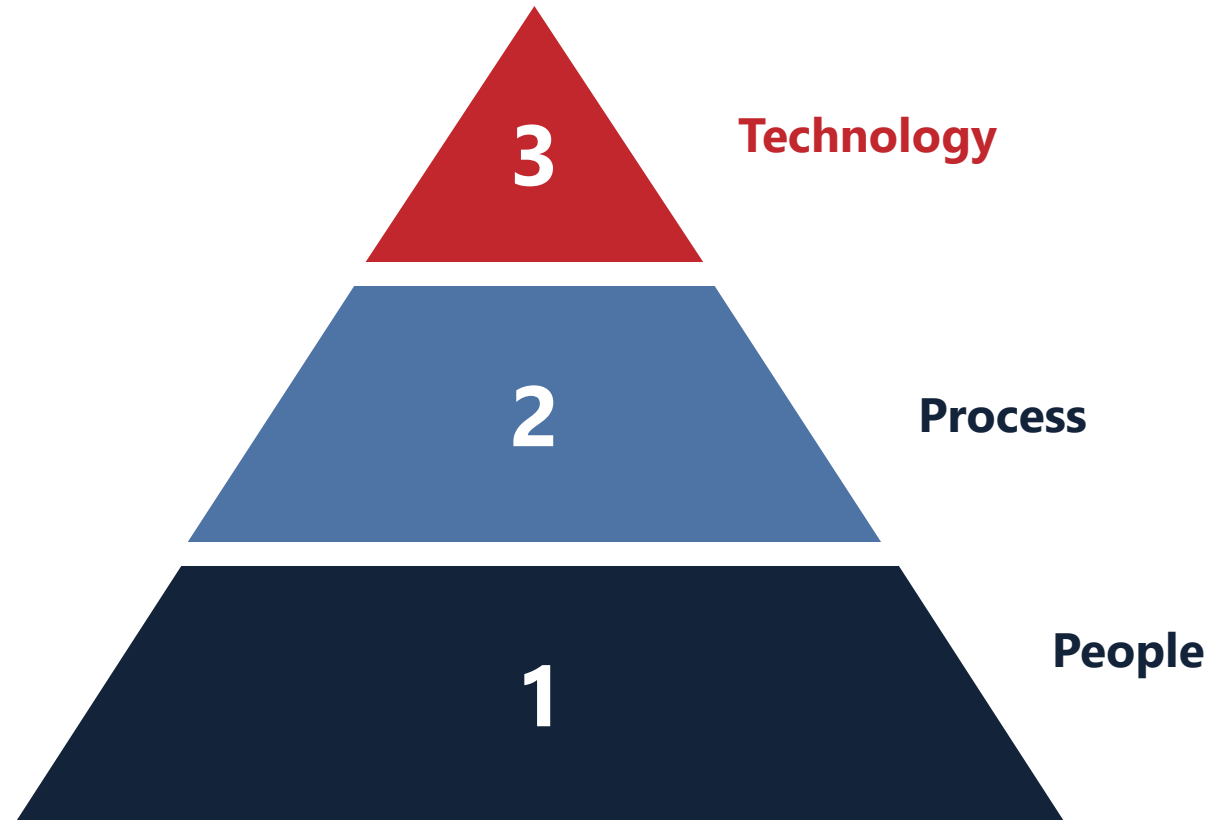
The thesis

**GenAI is a force multiplier.
It is not the decision-maker.**

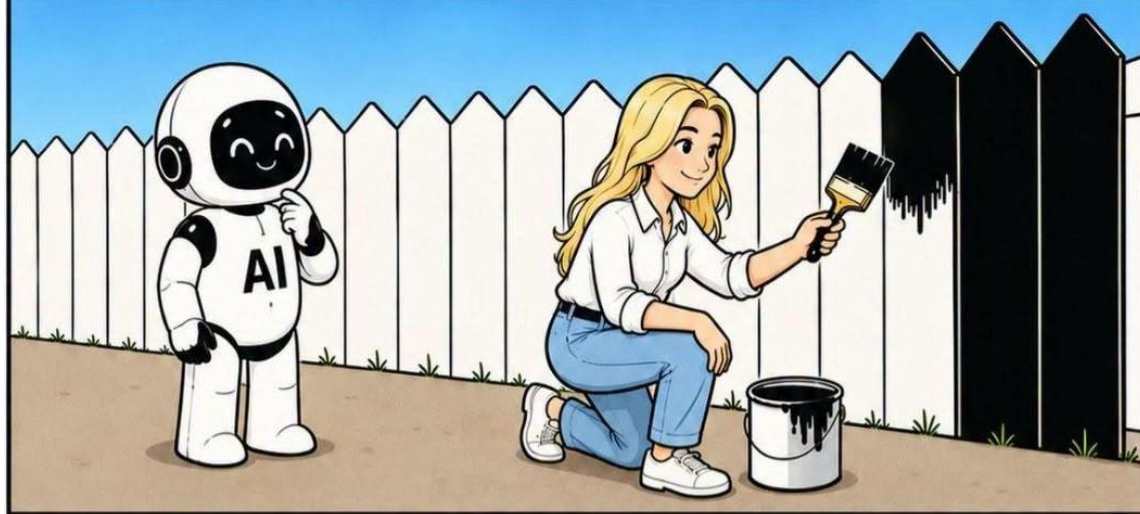
You give the context. You set the parameters. You decide.

People, process, technology isn't a stool. It's a pyramid.

- Interchangeable legs? They aren't.¹
- Right people first. Then process.
- Technology gets bolted on last.
- Skip a layer: it fails.



¹ Model from Leavitt (1965); full citation on references slide.





Making the Best Use of GenAI

Getting the most juice out of the squeeze

Use a harness, not just a chat window

Web app = a Corolla

- Reliable, zero training, gets you there
- Limited API, tool and local-machine access
- Slow to iterate, limited file types

Harness = an F1 car

- Real API, local and remote access
- Eats .zip and log files
- Tradeoff: basic CLI comfort



Build vs. buy on a lean team

Why build

- Fits how we actually work
- Ships in days, not quarters
- Cheap enough to just try

The catch

- You own it forever
- Undocumented means unsupportable
- Scope creep and key-person risk

Practitioner script beats 18-month roadmap.

Why scripts & API not ~~agents~~ & ~~MCP~~

- Non-determinism: same input, different output
- Great for creativity. Wrong for controls.
- Security lives on absolutes, not variables
- MCP in my testing: patchy coverage, shifts every release
- Auditable script beats trusted agent
- Vendor system cards admit these failure rates

In their own system cards

- Astra: fewer factual errors than GPT-5.6 Sol, still wrong on some
- Mythos 5.1 abstains less: more right answers and more wrong, net accuracy 0.57
- Mythos 5.1 is "less honest under pressure" on claims it judges low-harm

Fine for everyday use. Not fine as a control.

A script that is wrong is wrong every time, and you can find it.

Source: OpenAI GPT-6 Astra System Card, pp. 20–21, 76–82; Anthropic Claude Fable 5.1 and Claude Mythos 5.1 System Card, pp. 3, 122–123.

Trash in, trash out

Raw talent, junk fuel

- Good foundation, still bad output
- Wants greatness. No coach, no trainer.
- Doritos, Mountain Dew, never practices.

Coached, fueled, trained

- Another athlete, disciplined inputs
- Real reps, real feedback
- Same rule: context and data.



Nothing gets scheduled until it's verified

01

DEFINE

The problem comes from improvements
Ideate with the process owner

02

DRAFT

GenAI does the labor
You set the hard parameters

03

VERIFY

Test tenant or tight scope
Manually verify. Twice.
Refine on feedback

04

SCHEDULE

Only now does it recur
Nothing fires before this

Scheduling is last, never first.

Two habits before we look at the output

Prioritize

- High impact, low effort first
- Play it safe: start small

Version everything

- Save working copy before iterating
- You will break it.

Specific context improves every finding.



Use Cases

What I've actually built — and what went wrong along the way

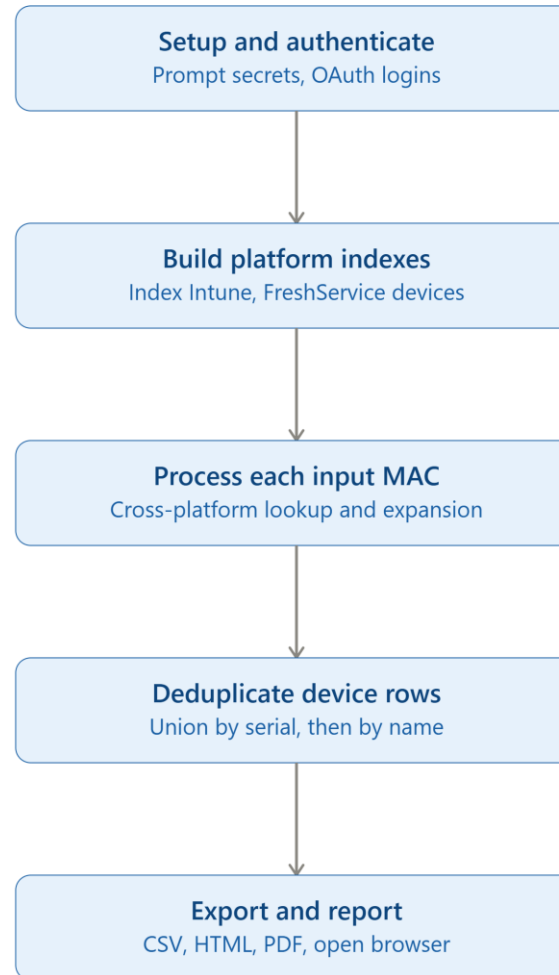


**What is the one task you would
hand off first?**

Hold that one in mind — the next section is my answer to it.

Inventory: classification and reporting at scale

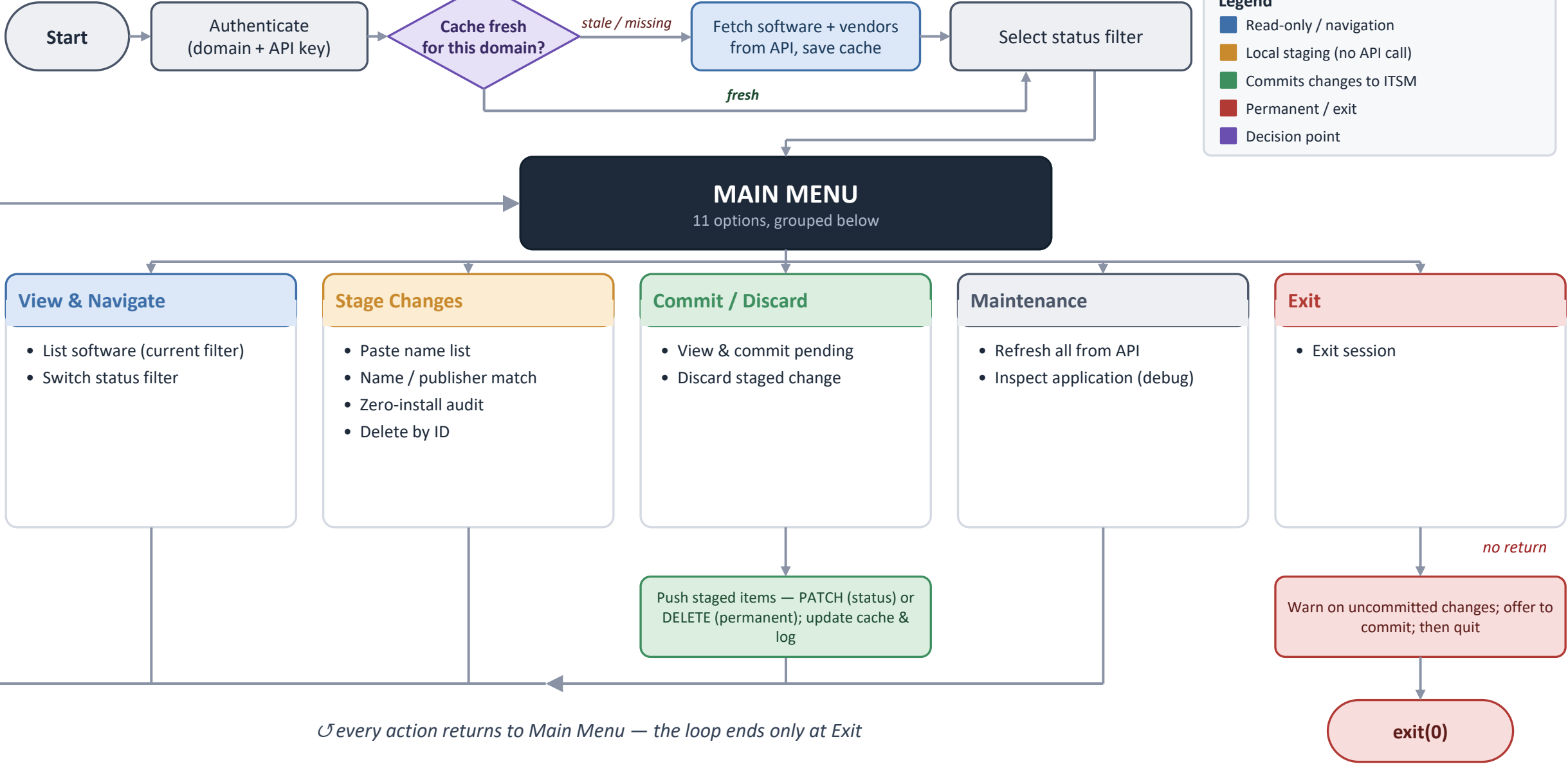
- Cross-inventory gaps:
ITSM, network, EDR



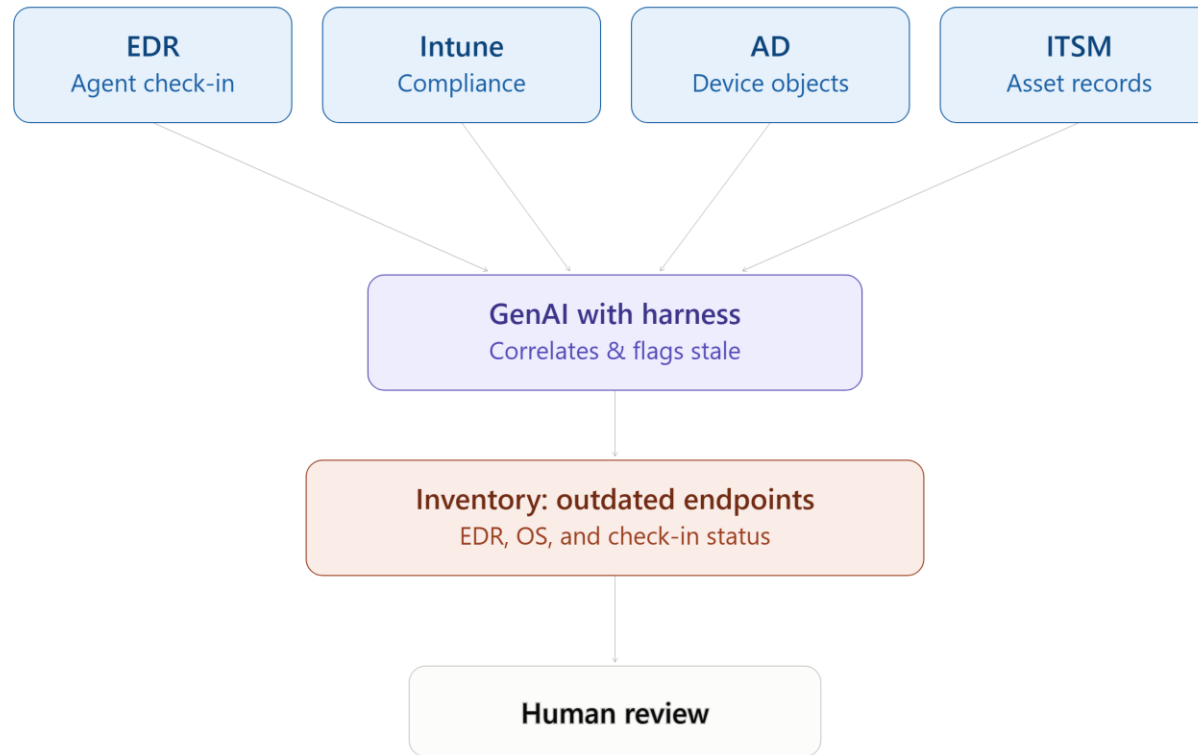
Hostname	MAC Address(es)	Serial	First Seen	Source	Discovery	MDM	ITSM	EDR
DEVICE-0001	ba:07:e5:2e:58:d1 Discovered: ba:07:e5:2e:58:d1 A6FA81458A2C	1YH8659	2026-09-08 10:50:43	SITE1-GW01/root/Data				
DEVICE-0003	b2:b5:a2:b9:1d:e2 Discovered: b2:b5:a2:b9:1d:e2		2026-09-04 12:58:00	SITE3-GW01/root/Data				
DEVICE-0004	12:c8:b4:18:28:25 Discovered: 12:c8:b4:18:28:25		2026-09-03 09:08:17	SITE2-GW01/root/Data				
DEVICE-0002 *	d6:2d:a4:7e:58:d0 All input: d6:2d:a4:7e:58:d0 0a:aa:f3:ea:b8:95 Discovered: d6:2d:a4:7e:58:d0 4E1852AF8707 0A:AA:F3:EA:B8:95 2 MACs merged	6N3VBNS	2026-09-03 07:29:30	SITE2-GW01/root/Data; SITE2-GW01/root/Data,SITE1-GW01/root/Data				
DEVICE-0005	42:47:97:49:bf:06 Discovered: 42:47:97:49:bf:06		2026-09-01 08:08:55	SITE1-GW01/root/Data				
DEVICE-0006	26:b6:82:5e:e4:37 Discovered: 26:b6:82:5e:e4:37		2026-09-01 05:58:24	SITE2-GW01/root/Data				
DEVICE-0007	9e:3b:97:d6:c1:c4 Discovered: 9e:3b:97:d6:c1:c4		2026-08-31 05:04:39	SITE4-GW01/root/Data				

Bulk Software Manager — Process Flow

Simplified program flow — credential check through committed changes

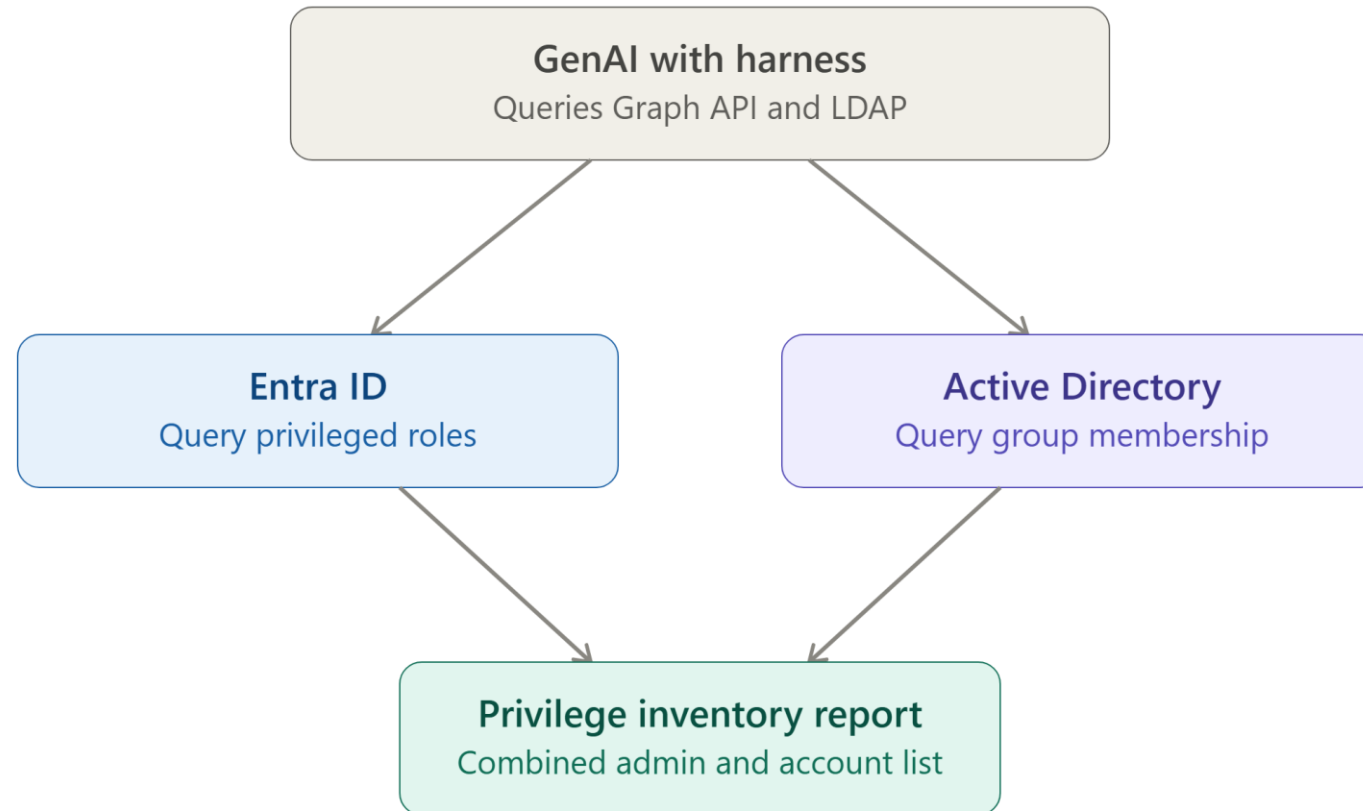


Inventory: Outdated endpoints (EDR/OS/Not checked in)



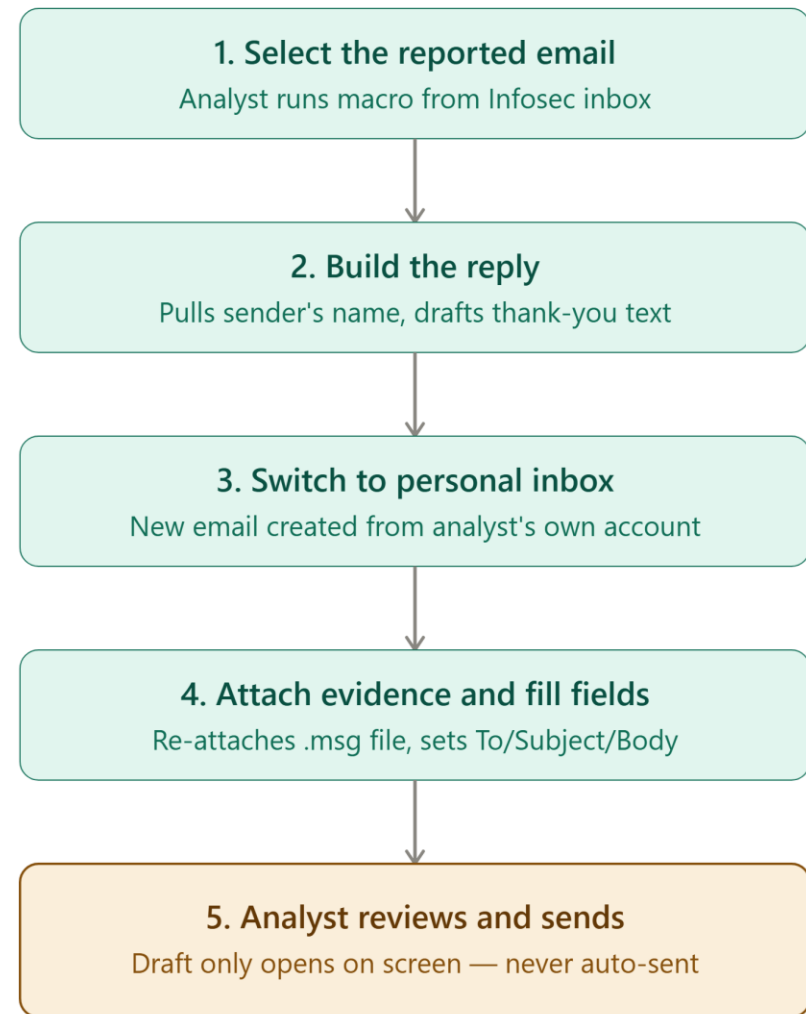
Privilege Inventory: Reporting at scale

- Make generic: Intune, Win32, EDR, privilege audits



Daily Speedups

- VBA script Macros for Outlook



Key safeguard

The macro always stops before sending.
A human must confirm and click Send —
nothing leaves the mailbox automatically.

Identity: who is actually protected?

- **CA-Audit** — users and devices graded
- **Analyze-ConditionalAccess** — gaps policies hide
- **AD / Entra ID sweeps** — delegation, MFA, accounts

Incident response and threat hunting

- **Monitor-RiskySignIns** — poll, score, alert
- **Sign-in analyzer** — VPN, proxy, Tor
- **Detect-PhishingCampaign** — reports to quarantine
- **Log analysis** — hardware, not Teams

GenAI supplies context. My thresholds decide.

Documentation: the work nobody wants to do

- change-management-request — records in house style
- problem-record — description in, record out
- Devil's advocate — argues against me

Drafting paperwork is easiest to hand off.

Deploy Win32 App to Intune

v2.02 automation flow · NEW / UPDATE / BUILT-IN modes · optional Phase II dynamic upgrade groups



NEW

Walks through every setting interactively to deploy a brand-new EXE application from scratch.

UPDATE

Reads an existing Intune app URL, copies its settings automatically, then deploys an updated EXE + version.

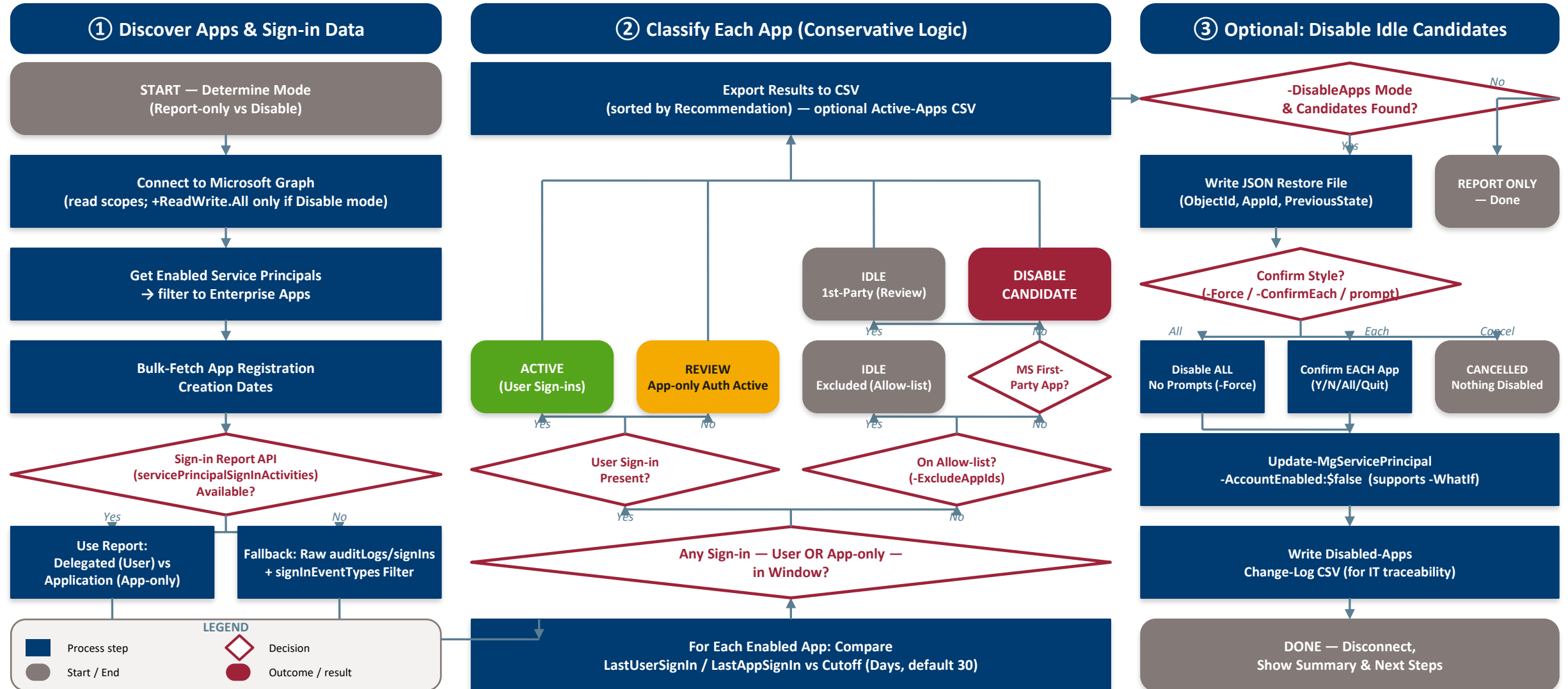
BUILT-IN

Pick one or more catalog apps (Adobe Reader, Zoom, Notepad++, PuTTY) — latest version auto-downloaded and deployed in a single authenticated run.

Unused Enterprise App Audit (v2) — Detection & Cleanup Logic

Finds enabled Entra ID Enterprise Apps with zero sign-in activity, then reports or safely disables the idle ones

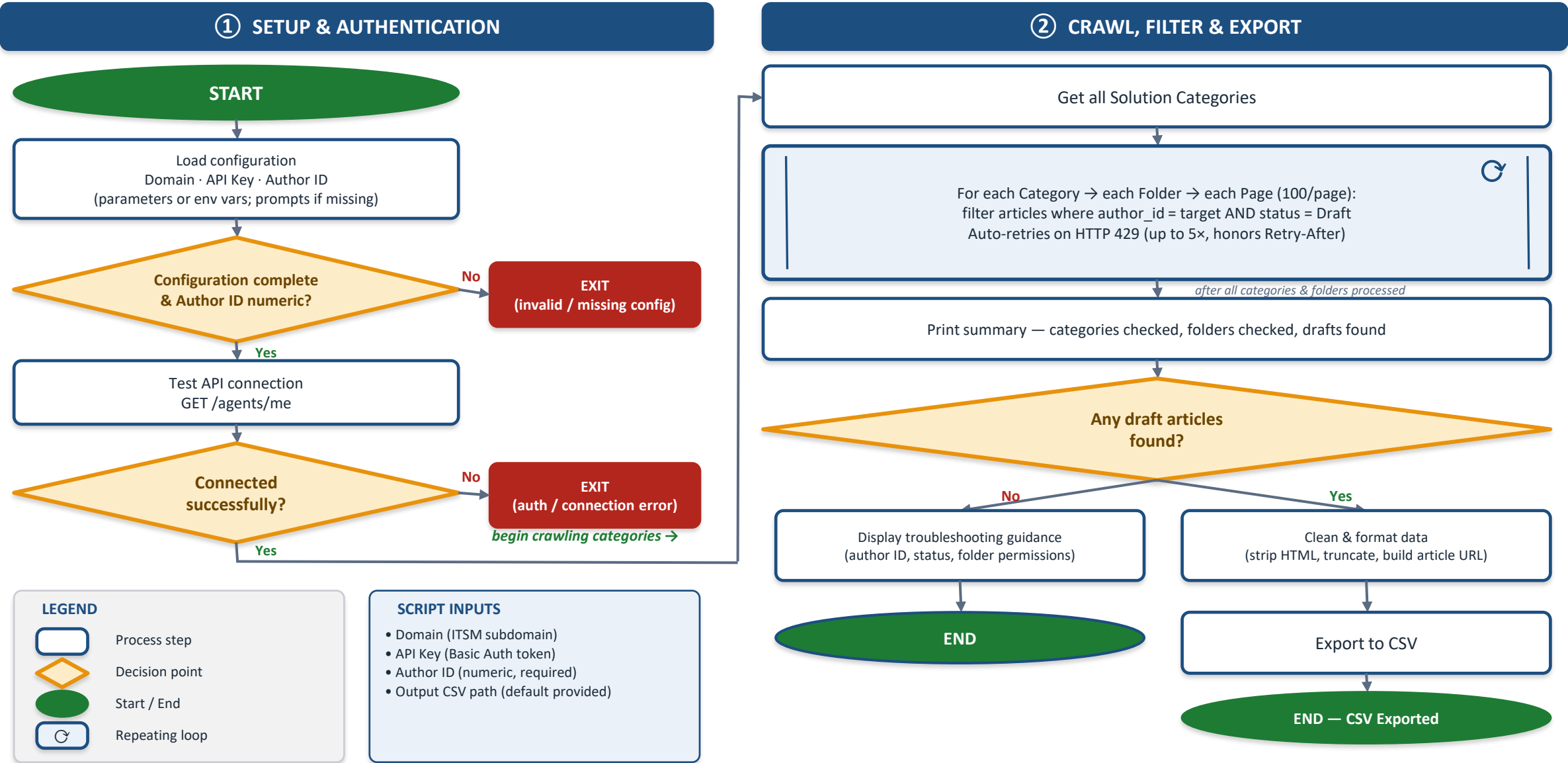
KEY FIX IN v2: v1 only queried interactive user sign-ins, so heavily-used app-only / service-principal apps could be wrongly flagged as unused. v2 pulls delegated AND application (app-only) sign-in activity before recommending anything.



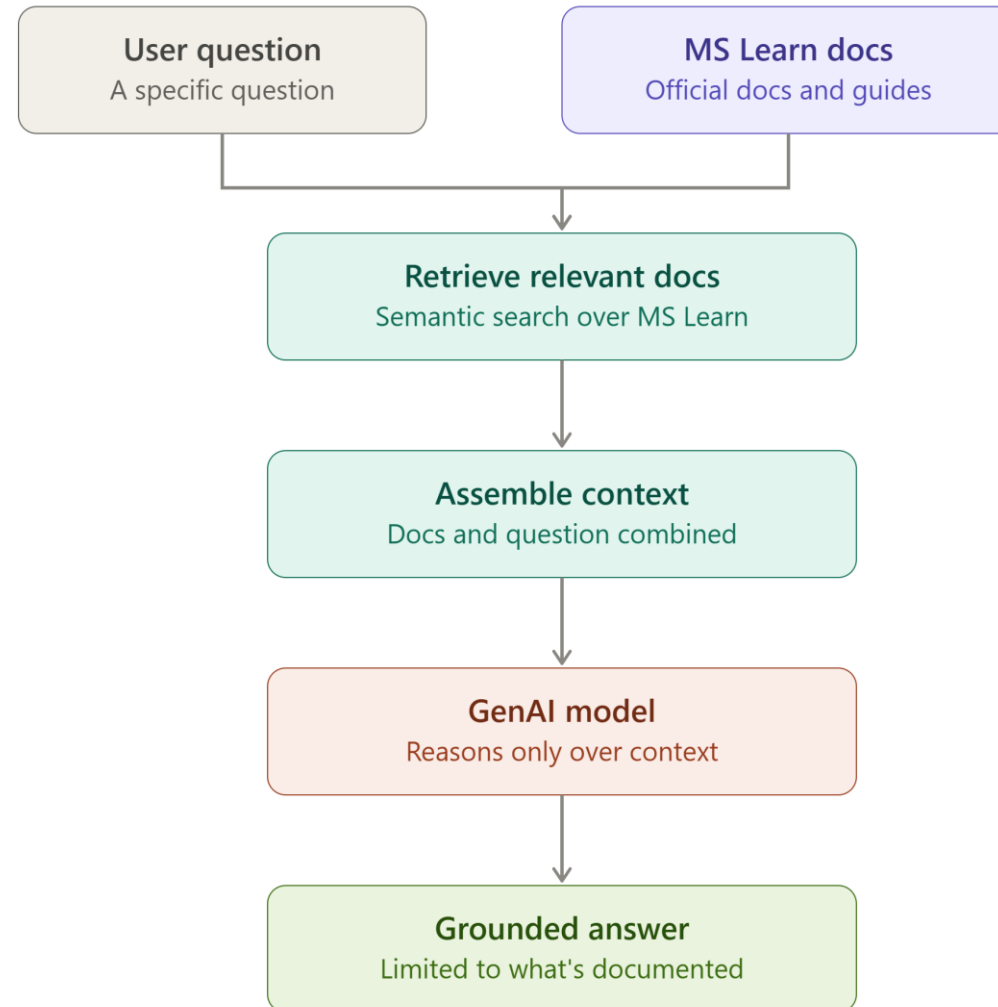
Requires Entra ID P1/P2 (sign-in activity) · Read scopes: AuditLog.Read.All, Application.Read.All, Directory.Read.All · +Application.ReadWrite.All only to disable

Draft Article Audit — Knowledge Base discovery and reporting

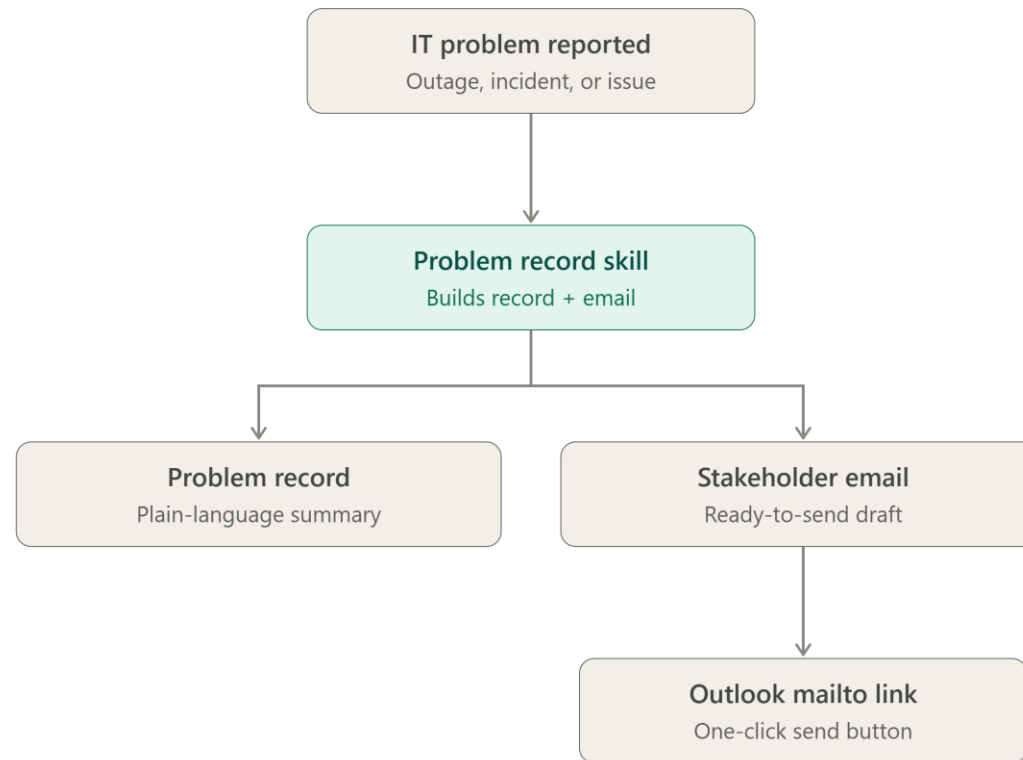
Process flow — audits the Knowledge Base for one author's draft articles and exports the matches to CSV



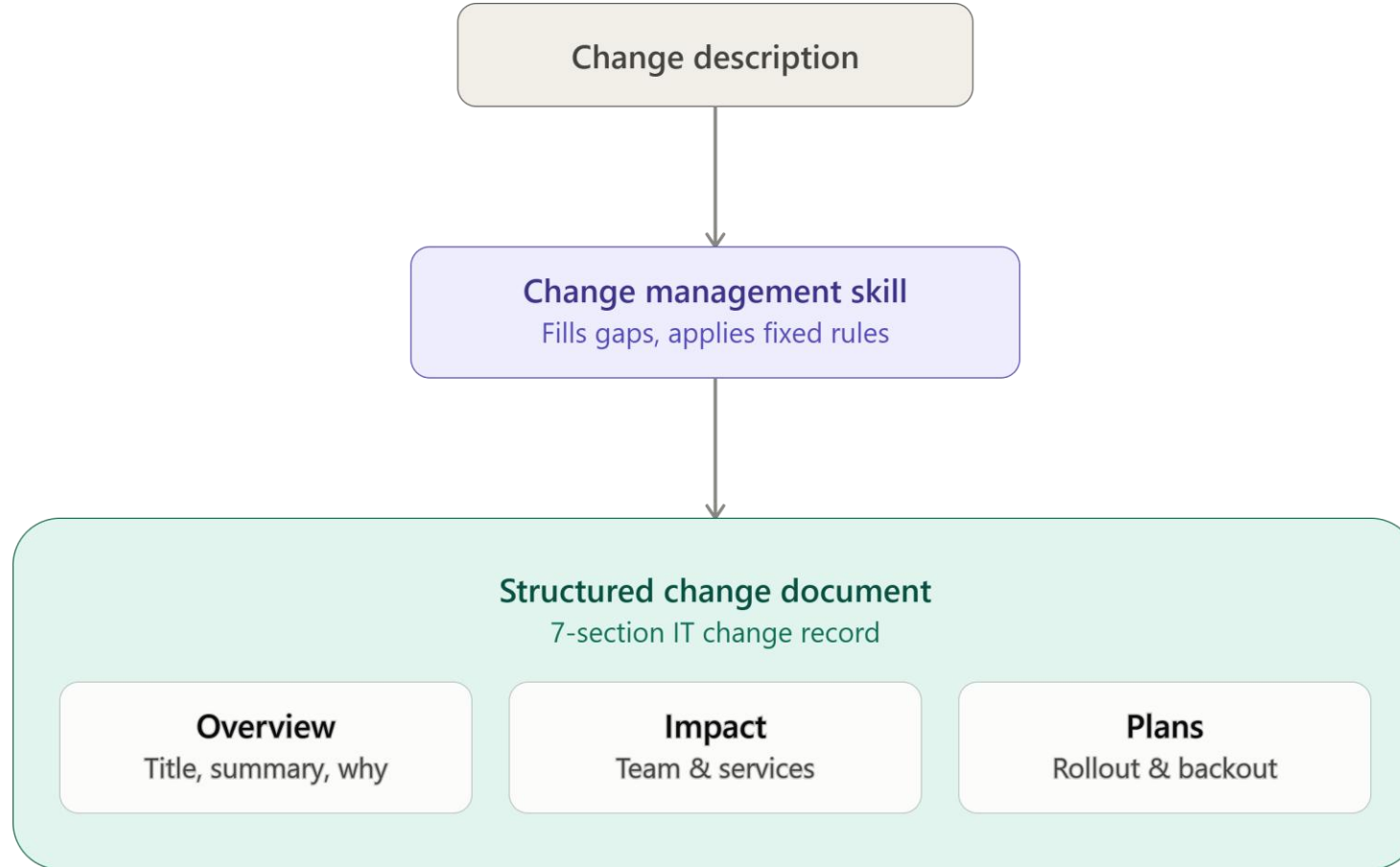
Grounded troubleshooting — official docs only



Problem record/ Outage workflow; text to speech walkthrough skill

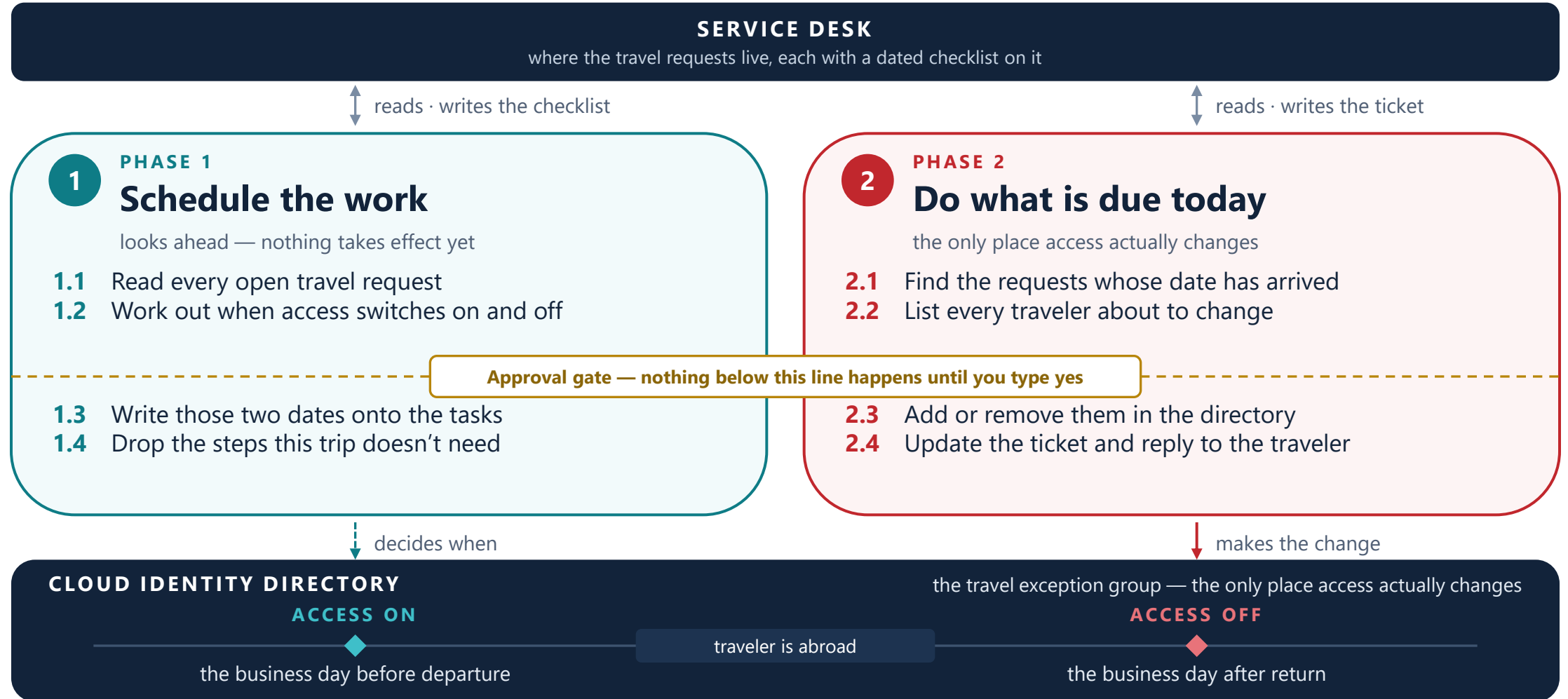


change-management-request — records in house style



The flagship: travel access, end to end

itsm_reassign_then_sync (v1.00 → v1.07) — one script: it schedules the trips coming up, then does what fell due today.



Firewall rules stay manual — the script prints the destination countries and the change for an analyst.

Run ad hoc since June 2026, moving to daily · 8 versions

Awareness training people will actually play

Taste test

THE HELP DESK SPECIAL · RECIPE 1 OF 3



Name-drop this week's real Outlook outage LANDED

Attackers read your status page, LinkedIn and the local press. One true detail buys credibility for a false request.



"Your account locks in ten minutes" LANDED

Urgency is the heat source — it stops people stepping away to verify. Any real deadline survives a five-minute check.



Ask for the password outright in the first twenty seconds BURNT IT

Too fast, too hot. Staff are drilled on this one, and IT never needs your password — they can reset it without ever hearing it.



Refuse to let them call the Service Desk back BURNT IT

The moment you block a callback you have announced you are not who you say. A real technician would encourage it.



Spoofed caller ID showing the real Service Desk number LEFT ON THE COUNTER

Caller ID is trivially forged — it is a suggestion, not proof. The defense is that SpawGlass IT will never mind you hanging up and dialing the Service Desk yourself.



Call-center chatter in the background LEFT ON THE COUNTER

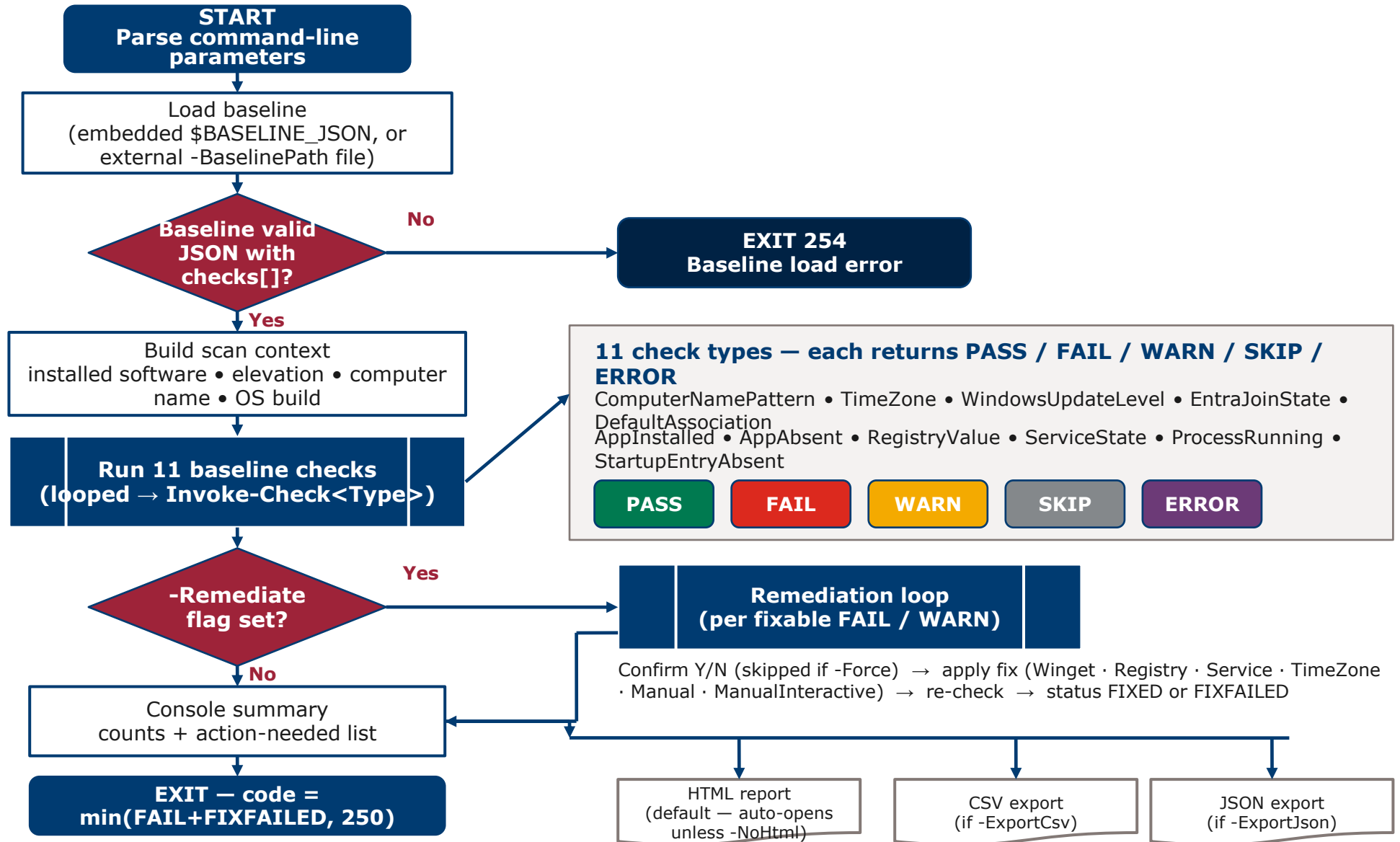
Ambient noise sells the pretext. A real support floor sounds like this, so your ear stops asking questions.

2 of 4 lures landed, 2 ingredients burnt the dish — 0 points this round, 0 so far.

Take the call →

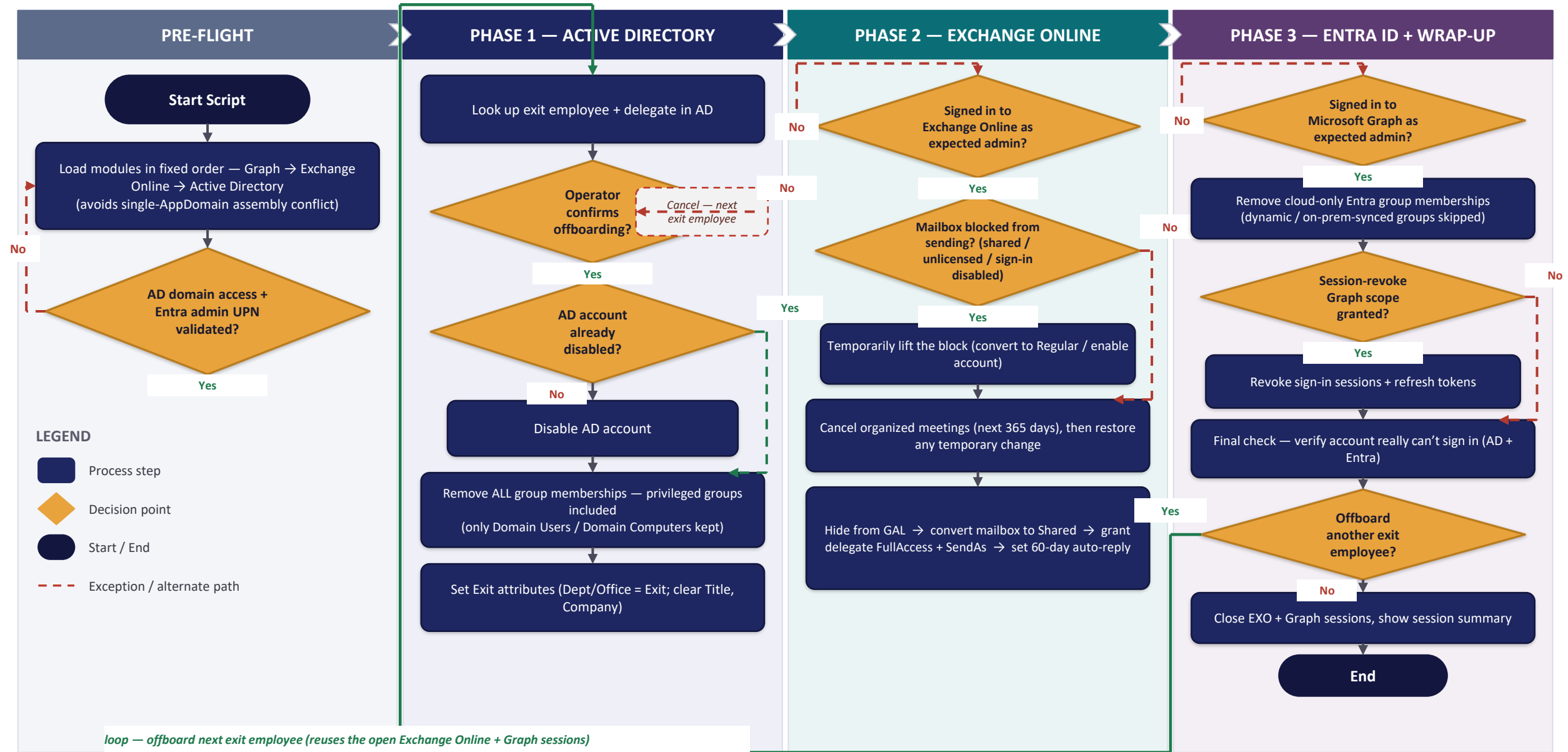
QC Checker v1.04 — Compliance Scan Engine

SpawGlass Windows 11 Settings Compliance Checker • baseline-driven PASS / FAIL / WARN engine with optional remediation



SpawGlass Employee Offboarding — Process Flow

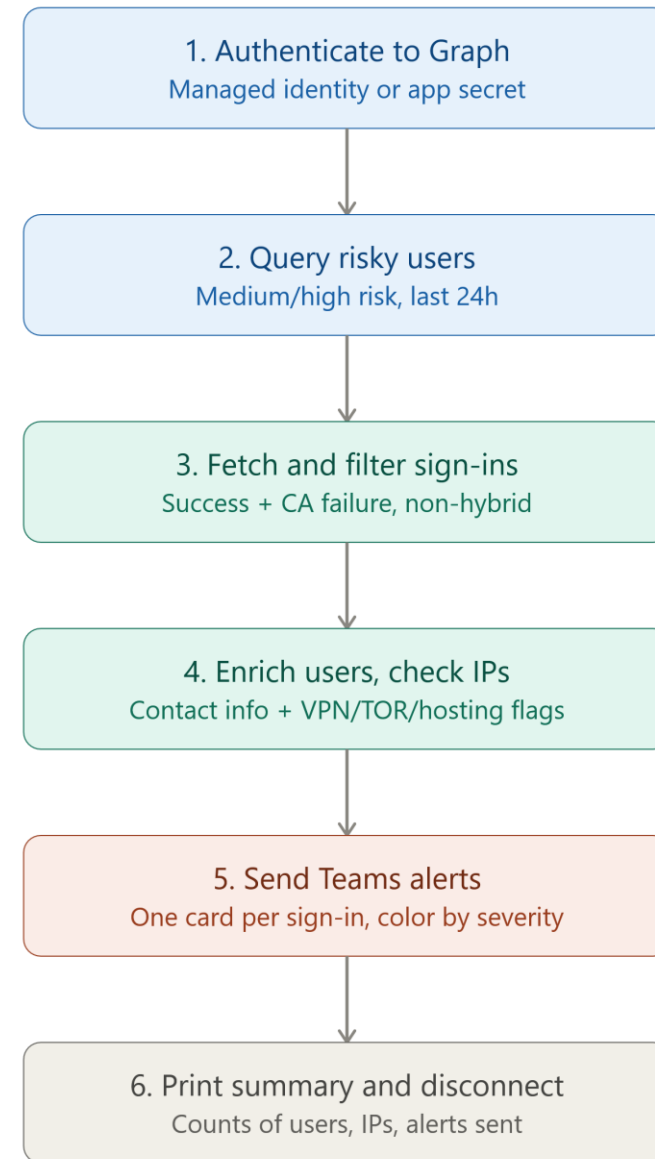
v3.08 • Hybrid: Active Directory + Exchange Online + Entra ID • supports multiple exit employees per run



Any unresolved temporary change (a lifted sign-in block, a mailbox converted back to Regular) is force-restored on every exit path, including crashes — a departed employee left able to sign in outweighs any step left unfinished.

Risky sign-in analyzer

1. The context and prompt given
2. The hard-parameter decision layer
3. The output landing in Teams



Risks and guardrails

- **Hallucination — confidently wrong rankings**
- **Data privacy and prompt injection**
- **It classifies. It never decides.**
- **Non-negotiables: dry-run, log, vault secrets**

If you do only three things

- 1. Pick one problem you already have**
- 2. Write the hard parameters yourself**
- 3. Verify manually. Twice.**



Talk resources & slides



Connect with me on LinkedIn

Questions?

References & Resources

Vendor System Cards

- **Claude Fable 5.1 and Claude Mythos 5.1 System Card** — Anthropic, September 2026. anthropic.com
- **Claude Opus 5 System Card** — Anthropic, July 2026; includes UK AISI cyber-range results. anthropic.com
- **GPT-6 Astra System Card** — OpenAI, 2026. deploymentsafety.openai.com/gpt-6-astra
- **GPT-5.6 System Card (Sol, Terra, Luna)** — OpenAI, June 2026, updated August 2026. deploymentsafety.openai.com
- **GPT-5.3-Codex System Card** — OpenAI, February 2026. openai.com

Security Awareness Games

- **Hallie Wiltshire**, Information Security Awareness Specialist, Charles River Labs — original game, presented at the SANS Security Awareness Summit: Advancing Security Culture, 2025. Our version is a spin-off. youtu.be/mVp6s3dL-p4

Academic & Research

- **Leavitt, H. J. (1965)**. Applied organizational change in industry: Structural, technological and humanistic approaches. In J. G. March (Ed.), *Handbook of Organizations* (pp. 1144–1170). Rand McNally.

Image credit: All images created with Google Gemini AI.